

INFORME DE INCIDENTE DE SEGURIDAD

Proyecto Final de Ciberseguridad - 4Geeks

João Paulo Medeiros

1. Introducción

El presente informe documenta el análisis realizado sobre múltiples vulnerabilidades identificadas en un servidor Debian Linux desplegado en un entorno controlado de laboratorio.

El objetivo principal fue analizar las fallas de seguridad detectadas, evaluar su impacto potencial, aplicar acciones correctivas y establecer medidas preventivas para reducir riesgos futuros.

Durante la investigación se identificaron configuraciones inseguras relacionadas con servicios FTP, SSH y WordPress, las cuales podrían comprometer la confidencialidad, integridad y disponibilidad del sistema.

2. Información General del Incidente

Elemento	Descripción
Sistema afectado	Debian Linux
Dirección IP	192.168.1.48
Máquina atacante	Kali Linux
Dirección IP atacante	192.168.1.49
Tipo de incidente	Configuración insegura y exposición de servicios
Nivel de criticidad	Alto
Fecha del análisis	Abril 2026

3. Resumen Ejecutivo

Durante el análisis de seguridad se detectaron varias configuraciones inseguras en servicios expuestos del servidor Debian. Las vulnerabilidades identificadas permitían:

- Acceso FTP mediante autenticación anónima
- Login remoto vía SSH utilizando la cuenta root
- Configuración incorrecta de WordPress utilizando localhost

Estas fallas representaban riesgos importantes de acceso no autorizado, exposición de servicios y compromiso total del sistema.

Tras la identificación de las vulnerabilidades, se aplicaron medidas correctivas para mitigar los riesgos detectados y reforzar la seguridad general del servidor.

4. Descripción del Incidente

4.1 Vulnerabilidad FTP — Acceso Anónimo Habilitado

Descripción

Se identificó que el servicio FTP permitía autenticación utilizando el usuario anonymous. Esto permitía acceso al servicio sin necesidad de credenciales válidas.

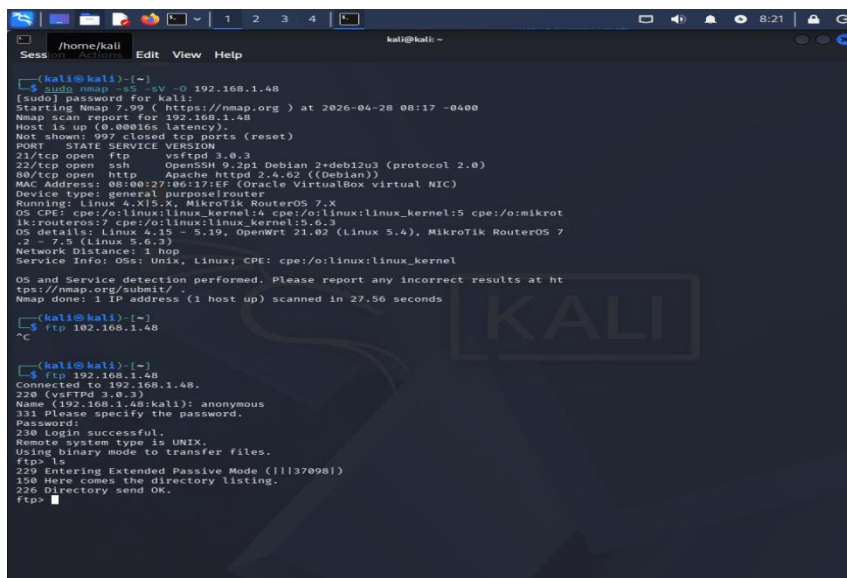
Evidencia

Comando utilizado:

```
ftp 192.168.1.48
```

Resultado:

```
230 Login successful.
```



```
(kali@kali)-[~]
└─$ sudo nmap -sS -v -o 192.168.1.48
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 08:17 -0400
Nmap scan report for 192.168.1.48
Host is up (0.00016s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:106:17:EF (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, Mikrotik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:s cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: Os: Linux, CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 27.56 seconds

(kali@kali)-[~]
└─$ ftp 192.168.1.48
230
(kali@kali)-[~]
└─$ ftp 192.168.1.48
Connected to 192.168.1.48.
220 (vsftpd 3.0.3)
Name (192.168.1.48:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||37098|)
150 Here comes the directory listing.
226 Directory send OK.
ftp>
```

Impacto

- Enumeración de directorios
- Exposición de archivos
- Posibles accesos indebidos en caso de permisos inseguros

Nivel de riesgo

Medio

4.2 Vulnerabilidad SSH — Login remoto como root

Descripción

Se detectó que el servidor permitía el acceso remoto vía SSH utilizando directamente el usuario root.

Evidencia

Comando utilizado:

```
ssh root@192.168.1.48
```

Resultado:

```
root@debian:~#
```

```
kali@kali:~$ ssh root@192.168.1.48
Warning: Permanently added '192.168.1.48' (ED25519) to the list of known hosts.
root@192.168.1.48's password:
Linux debian 6.1.8-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@debian:~# whoami
root
root@debian:~# pwd
/root
root@debian:~# cat /etc/ssh/sshd_config | grep -i permitrootlogin
PermitRootLogin yes
# the setting of "PermitRootLogin prohibit-password".
root@debian:~#
```

Verificación de configuración

Comando utilizado:

```
cat /etc/ssh/sshd_config | grep -i permitrootlogin
```

Resultado:

```
PermitRootLogin yes
```

```
kali@kali:~$ cat /etc/ssh/sshd_config | grep -i permitrootlogin
PermitRootLogin yes
# the setting of "PermitRootLogin prohibit-password".
root@debian:~#
```

Impacto

- Acceso administrativo completo
- Posibilidad de modificación del sistema
- Riesgo de persistencia maliciosa
- Riesgo de eliminación de evidencias
- Posible compromiso total del servidor

Nivel de riesgo

Crítico

4.3 Vulnerabilidad WordPress — Configuración incorrecta

Descripción

Se identificó que WordPress estaba configurado utilizando localhost como dirección principal del sitio. Esto provocaba errores de redireccionamiento y fallas de acceso remoto.

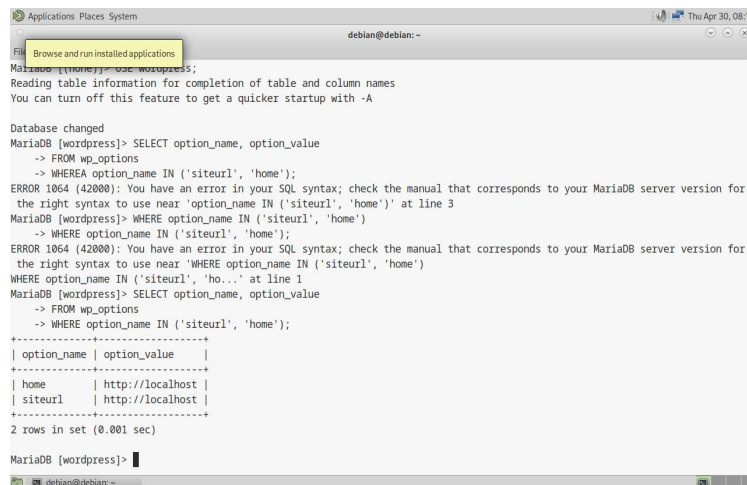
Evidencia

Consulta realizada:

```
SELECT option_name, option_value FROM wp_options WHERE option_name IN ('siteurl', 'home');
```

Resultado:

```
home | http://localhost
siteurl | http://localhost
```



```
Applications Places System
debian@debian: ~
MariaDB [(wordpress)]> SELECT option_name, option_value
FROM wp_options
WHERE option_name IN ('siteurl', 'home');
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for
the right syntax to use near 'option_name IN ('siteurl', 'home')' at line 3
MariaDB [(wordpress)]> WHERE option_name IN ('siteurl', 'home')
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for
the right syntax to use near 'WHERE option_name IN ('siteurl', 'home')' at line 1
MariaDB [(wordpress)]> SELECT option_name, option_value
FROM wp_options
WHERE option_name IN ('siteurl', 'home');
+-----+-----+
| option_name | option_value |
+-----+-----+
| home        | http://localhost |
| siteurl     | http://localhost |
+-----+-----+
2 rows in set (0.001 sec)

MariaDB [(wordpress)]>
```

Impacto

- Indisponibilidad parcial de la aplicación
- Errores de acceso remoto
- Fallas administrativas
- Comportamiento incorrecto del sitio web

Nivel de riesgo

Medio

4.4 Vulnerabilidad WordPress — Permisos inseguros en wp-config.php

Descripción

Durante la revisión de seguridad del entorno WordPress, se identificó que el archivo wp-config.php presentaba permisos excesivamente permisivos (777), permitiendo lectura, escritura y ejecución para todos los usuarios del sistema. Este archivo contiene las credenciales de acceso a la base de datos MariaDB, por lo que su exposición representa un riesgo crítico para la confidencialidad de la aplicación.

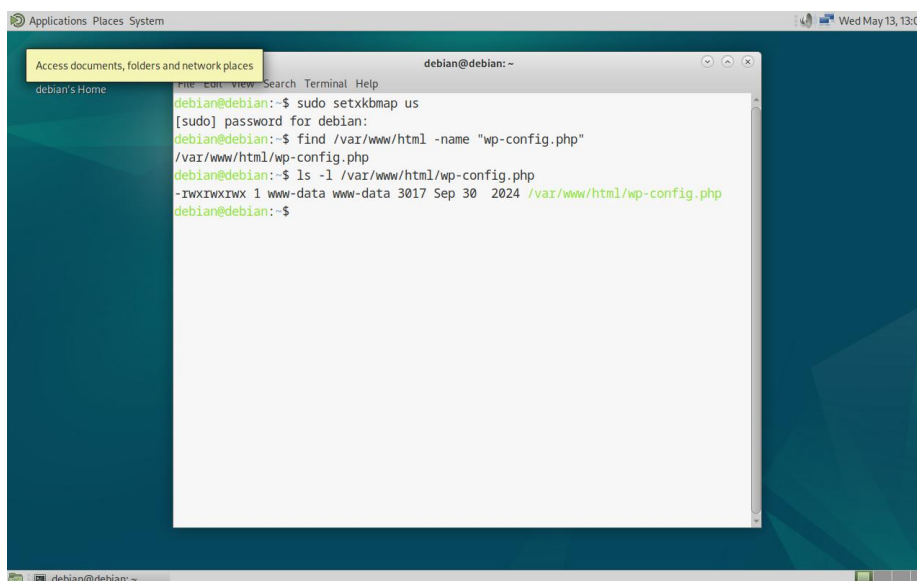
Evidencia

Comando realizado:

```
find /var/www/html -name "wp-config.php"
ls -l /var/www/html/wp-config.php
```

Resultado:

```
-rwxrwxrwx
```



Impacto

- Exposición de credenciales de la base de datos
- Posibilidad de lectura del archivo por cualquier usuario del sistema
- Riesgo de modificación del archivo de configuración
- Compromiso potencial de la base de datos WordPress

Nivel de riesgo

Medio

5. Análisis Técnico del Incidente

Durante el análisis se realizaron actividades de reconocimiento, enumeración y validación de vulnerabilidades. Las principales herramientas utilizadas fueron:

Herramienta	Objetivo
Nmap	Escaneo de puertos y servicios
FTP	Validación de acceso anónimo
SSH	Validación de autenticación remota
Gobuster	Enumeración web
MariaDB	Revisión de configuración del WordPress

El análisis permitió confirmar que las vulnerabilidades detectadas eran explotables en el entorno evaluado.

6. Acciones Correctivas Aplicadas

6.1 Corrección FTP

Archivo modificado: /etc/vsftpd.conf

Configuración aplicada:

```
anonymous_enable=NO
```

Resultado: Bloqueo del acceso anónimo FTP

6.2 Corrección SSH

Archivo modificado: /etc/ssh/sshd_config

Configuración aplicada:

```
PermitRootLogin no
```

Resultado: Bloqueo del login remoto como root

6.3 Corrección WordPress

Consultas aplicadas:

```
UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='siteurl';
```

```
UPDATE wp_options SET option_value='http://192.168.1.48' WHERE option_name='home';
```

Resultado: Funcionamiento correcto del WordPress mediante IP remota

6.4 Corrección WordPress - Permisos wp-config

Archivo: /var/www/html/wp-config.php

Configuración aplicada:

```
sudo chmod 600 /var/www/html/wp-config.php
```

Resultado: Acceso restringido exclusivamente al propietario

7. Validación de las Correcciones

Después de aplicar las medidas correctivas, se realizaron nuevas pruebas de validación.

Vulnerabilidad	Resultado
FTP anonymous	Bloqueado
SSH root login	Bloqueado
WordPress localhost	Corregido
WordPress wp-config.php	Corregido

Las pruebas confirmaron que las vulnerabilidades fueron mitigadas correctamente.

8. Medidas Preventivas Recomendadas

- Deshabilitar accesos anónimos en servicios FTP
- Evitar login remoto directo con root
- Utilizar autenticación SSH mediante claves públicas
- Aplicar políticas de contraseñas robustas
- Monitorear logs de autenticación
- Revisar periódicamente servicios expuestos
- Mantener actualizaciones del sistema
- Aplicar hardening en servidores Linux
- Realizar auditorías periódicas
- Implementar monitoreo continuo de seguridad

9. Lecciones Aprendidas

El incidente evidenció la importancia de revisar configuraciones por defecto, restringir accesos administrativos y minimizar la exposición de servicios. Estos aprendizajes fueron incorporados en el Plan de Recuperación y Respuesta ante Incidentes.

10. Conclusión

El análisis realizado permitió identificar múltiples vulnerabilidades de seguridad en el servidor Debian analizado. Las principales fallas estaban relacionadas con configuraciones inseguras en servicios críticos expuestos a la red, especialmente FTP y SSH.

Todas las vulnerabilidades identificadas fueron corregidas exitosamente y posteriormente validadas mediante nuevas pruebas.